AEGIS
SIEM · XDR
Supervision & détection de sécurité

eFrei
PARIS PANTHÉON-ASSAS UNIVERSITÉ



Aegis,

Déploiement d'une plateforme SIEM & XDR

Rapport de projet - Efrei

Equipe SR05E

2025-2026

Étudiants : El Assad SAID, Yassine TENZEKHTI, Arthur SAVATIER, Thibault TEILLET, Yanis OUAHAB, Meriem TIH

Mentor : Abdelkrim LAHLOU

Table des matières

Table des matières....2
1. Introduction et contexte....3
1.1. Objectifs....3
2. Choix de la solution technologique....4
3. Environnement et architecture générale....5
3.1. Vue d'ensemble des trois phases....6
4. Phase 1 - Déploiement All-in-One....6
4.1 Installation de la plateforme....7
4.2. Intégration des sources surveillées....7
4.3. File Integrity Monitoring....8
4.4. Premiers résultats et tableaux de bord....9
4.5. Conformité RGPD (niveau 1)....9
5. Phase 2 - Déploiement multi-noeuds....10
6. Phase 3 - Cluster et conteneurisation....12
7. Conformité réglementaire....12
7.1. Conformité RGPD....12
7.1.1. FInalité et base légale....12
7.1.2. Données traitées et minimisation....13
7.1.3. Contrôle d'accès et sécurité (article 32)....15
7.1.4. Politique de rétention....17
7.1.5. Localisation des données....18
7.1.6. Analyse de risque (synthèse)....19
7.2. Conformité ISO/IEC 27001 (Phase 2)....19
7.3. Conformité PCI DSS (Phase 3)....22
8. Cas d'usage et démonstrations....22
9. Organisation et gestion de projet....24
10. Conclusion....25

1. Introduction et contexte

Ce projet a pour objet la conception et le déploiement d'une plateforme de supervision de sécurité de type SIEM (Security Information and Event Management) et XDR (Extended Detection and Response), reposant exclusivement sur des technologies open-source. L'objectif n'est pas d'imposer une solution, mais d'analyser, d'évaluer et de sélectionner une architecture adaptée aux besoins techniques et organisationnels, puis de la déployer selon une démarche progressive.

La plateforme doit assurer une supervision de sécurité centralisée et intégrer des sources de données hétérogènes afin d'offrir une visibilité complète sur l'infrastructure et des capacités de détection des menaces. Elle doit également respecter des exigences de conformité réglementaire, avec au minimum une conformité au RGPD en matière de protection des données, de gestion des journaux et de bonnes pratiques de sécurité, renforcée par ISO/IEC 27001 puis PCI DSS aux niveaux avancés.

Le projet est structuré en trois phases de maturité croissante : un déploiement minimal centralisé (all-in-one), un déploiement intermédiaire distribué (multi-nœuds), puis un déploiement avancé de niveau entreprise (cluster conteneurisé). Il est mené par une équipe de six étudiants travaillant à distance.

1.1. Objectifs

- Concevoir et déployer une plateforme SIEM/XDR open-source fonctionnelle.
- Intégrer des sources hétérogènes (postes, serveurs, équipements réseau) et démontrer des cas d'usage de détection.
- Faire évoluer l'architecture d'un modèle centralisé vers un modèle distribué et conteneurisé.
- Assurer la conformité RGPD, puis ISO/IEC 27001 et PCI DSS.

2. Choix de la solution technologique

L'énoncé impose une solution open-source mais laisse le choix de l'outil. Trois solutions de référence ont été comparées : Wazuh, la suite Elastic (ELK) et Graylog.

Critère	Wazuh	Elastic (ELK)	Graylog
Fonctions SIEM	Oui	Oui	Oui
Fonctions XDR (agents)	Oui (natif)	Partiel (Elastic Agent)	Non natif
File Integrity Monitoring	Oui (natif)	Non natif	Non natif
MITRE ATT&CK	Intégré	Elastic Security	Limité
Tableaux de bord conformité	RGPD/ISO/PCI intégrés	A construire	Limité
Complexité de mise en oeuvre	Moyenne	Elevée	Moyenne

La solution **Wazuh** a été retenue car elle couvre nativement à la fois les fonctions SIEM (collecte et corrélation de journaux) et XDR (détection sur les endpoints via agents), et intègre directement les modules attendus par le projet : File Integrity Monitoring, détection de vulnérabilités, cartographie MITRE ATT&CK, réponse automatisée et tableaux de bord de conformité. Ce périmètre fonctionnel permet de couvrir les trois phases sans changer d'outil, tout en restant à 100 % open-source.

Wazuh repose sur trois composants : le **serveur (manager)** qui applique le décodage, les règles et la corrélation ; l'**indexeur** qui stocke et indexe les événements ; et le **tableau de bord** de visualisation. Des **agents** sont déployés sur les machines surveillées, et la collecte **syslog sans agent** est utilisée pour les équipements réseau.

3. Environnement et architecture générale

La plateforme est hébergée sur un serveur **OVHcloud VPS-4** (8 vCore, 24 Go de RAM, 200 Go NVMe) situé au datacenter de **Strasbourg (France)**, sous **Ubuntu Server 24.04 LTS**, dernière version supportée par Wazuh 4.14. Ce dimensionnement permet de porter les trois phases sur un même serveur, les architectures distribuées étant simulées par conteneurs.

Les machines surveillées, hébergées par les membres de l'équipe, sont reliées au serveur par un **réseau privé virtuel (Tailscale, chiffré)**, sans exposer la plateforme sur l'Internet public. Le code de configuration est versionné dans un **dépôt Git** partagé, et le projet est organisé en sprints avec une répartition des rôles sur les six membres.

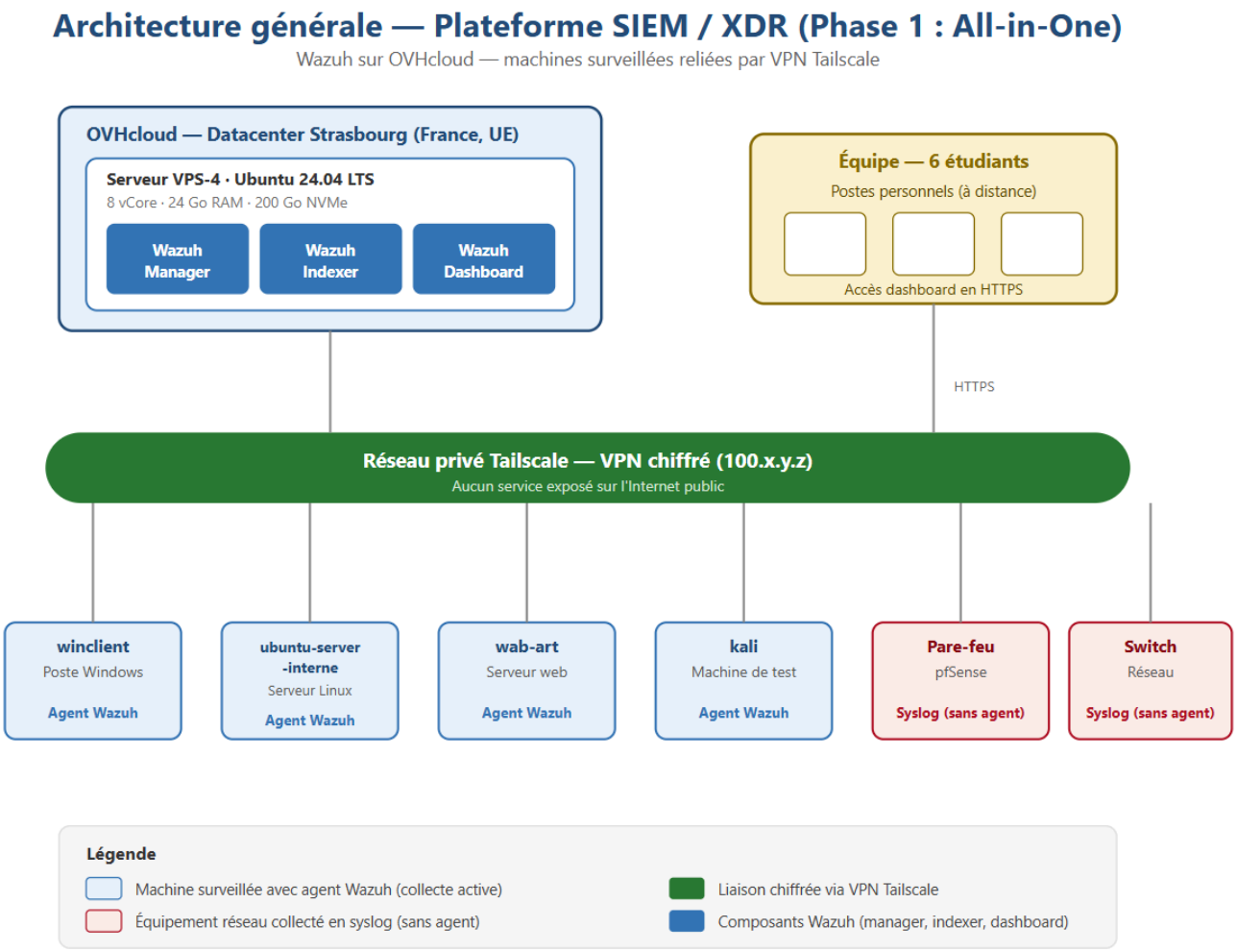


Schéma d'architecture générale

3.1. Vue d'ensemble des trois phases

Phase	Architecture	Mise en oeuvre
Phase 1	All-in-One	Installation native de Wazuh (manager + indexeur + dashboard) sur le VPS
Phase 2	Multi-noeuds	Noeuds séparés en conteneurs Docker (manager, indexeur, dashboard)
Phase 3	Cluster	Cluster + load balancing conteneurisés ; option Kubernetes managé OVH

4. Phase 1 - Déploiement All-in-One

La première phase valide le concept SIEM/XDR sur une architecture centralisée : tous les composants Wazuh sont installés sur le VPS, et les premières sources de données sont intégrées.

4.1 Installation de la plateforme

Wazuh a été installé en mode all-in-one à l'aide du script d'installation officiel, déployant le manager, l'indexeur et le tableau de bord. Les trois services sont actifs et le tableau de bord est accessible en HTTPS via l'adresse privée du serveur.

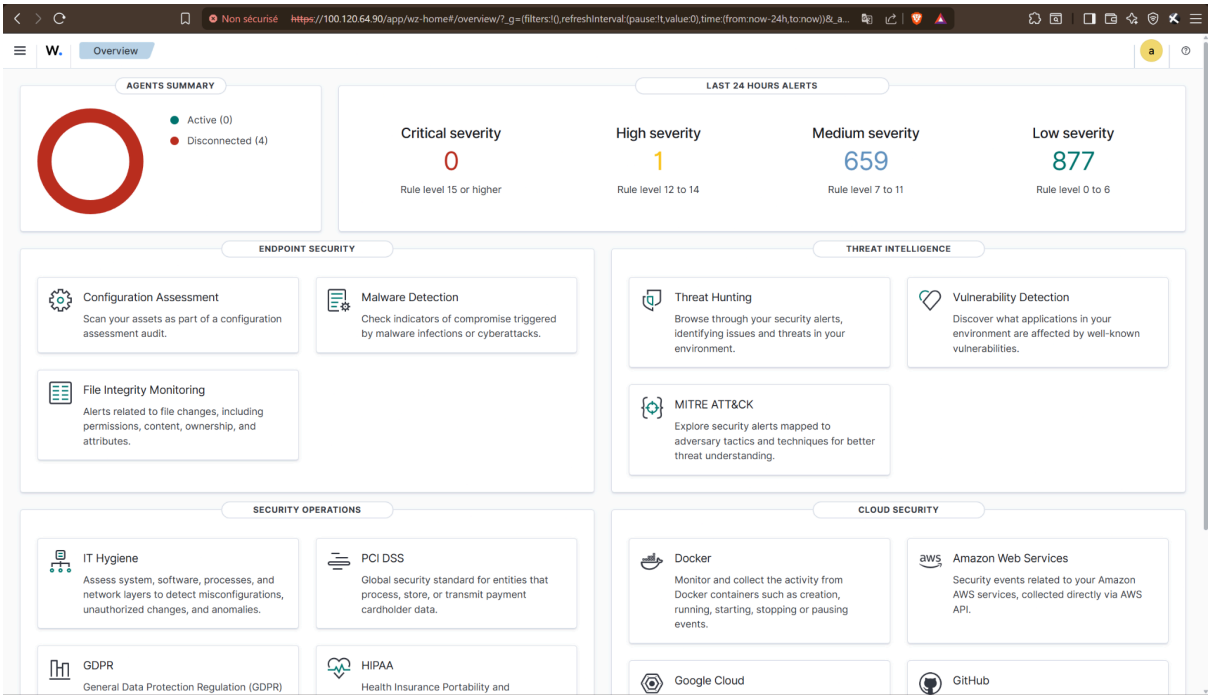


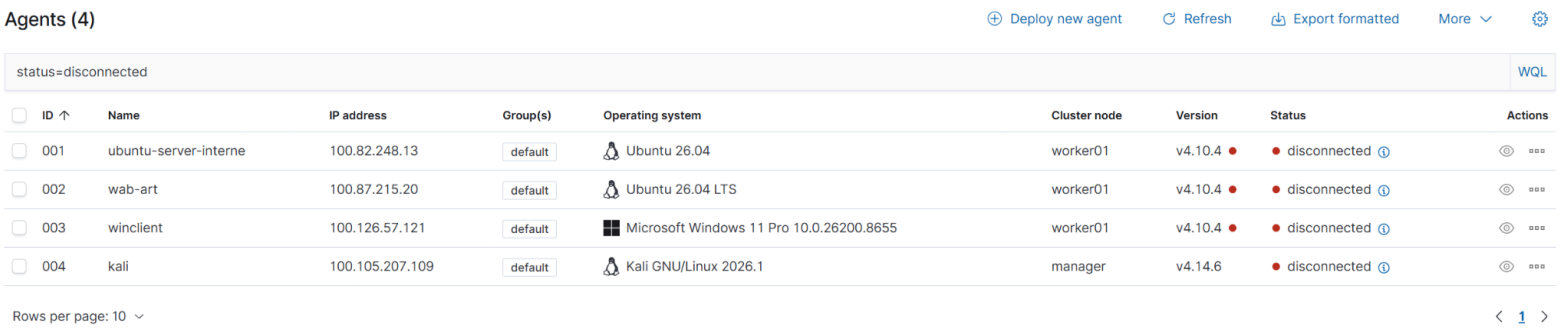
Tableau de bord Wazuh après connexion

4.2. Intégration des sources surveillées

Plusieurs agents ont été enrôlés sur les machines de l'équipe, couvrant des systèmes hétérogènes : poste Windows, serveur Linux interne, serveur web et machine de test. La collecte syslog sans agent est prévue pour les équipements réseau (pare-feu, commutateur).

Agent	Type de système	Mode de collecte
winclient	Poste Windows	Agent
ubuntu-server-interne	Serveur Linux	Agent
wab-art	Serveur web	Agent
kali	Machine de test / attaquant	Agent

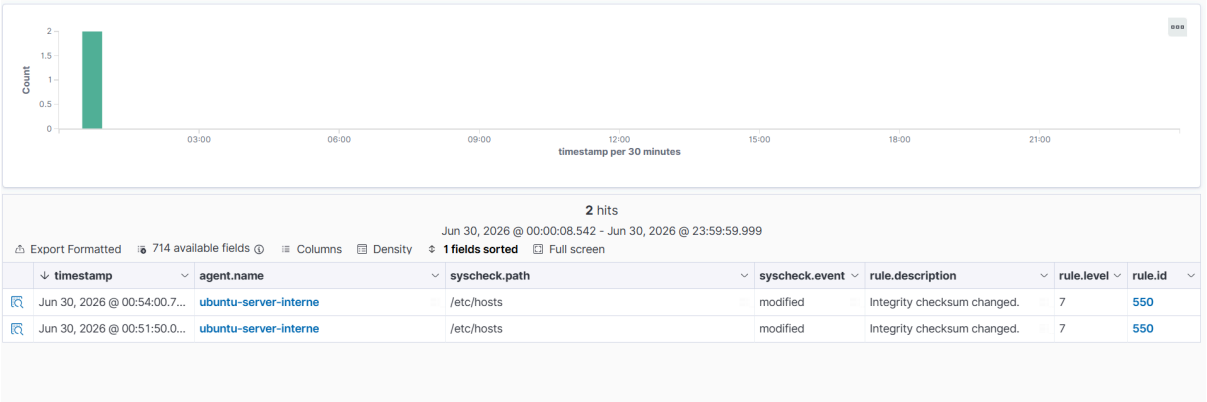
Pare-feu / switch	Equipement réseau	Syslog (à intégrer)



Liste des agents dans le dashboard (menu Agents)

4.3. File Integrity Monitoring

Le module de surveillance de l'intégrité des fichiers (FIM) a été activé sur les agents pour détecter toute modification de fichiers sensibles. Un test de modification a permis de vérifier la génération d'une alerte d'intégrité.



4.4. Premiers résultats et tableaux de bord

Le tableau de bord Threat Hunting agrège les événements collectés et fait apparaître les premières détections. Sur une période de 24 heures, la plateforme a traité plus d'un millier d'événements, dont des tentatives d'authentification (échecs et succès) et des techniques cartographiées MITRE ATT&CK (Valid Accounts, Password Guessing, Brute Force, SSH).

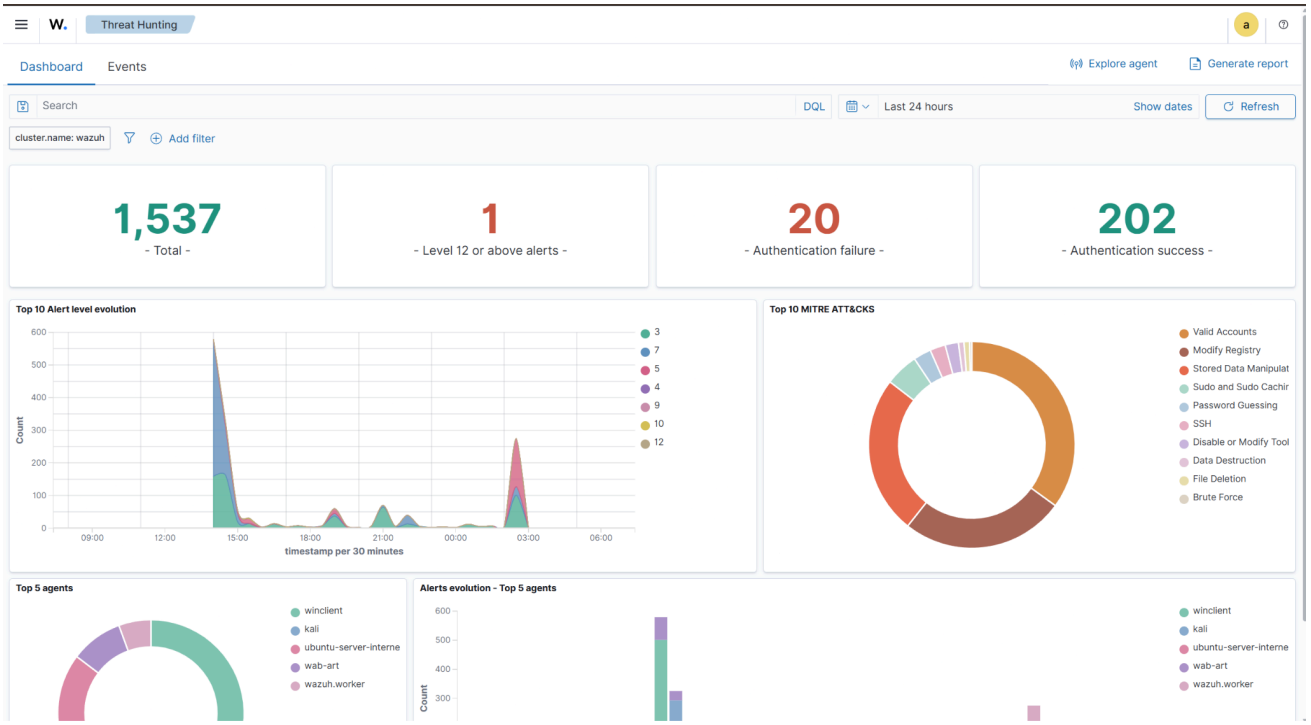


Tableau de bord Threat Hunting

4.5. Conformité RGPD (niveau 1)

La conformité RGPD associée à cette phase est traitée au chapitre 7, qui constitue le volet conformité complet du rapport.

5. Phase 2 - Déploiement multi-noeuds

La deuxième phase distribue les rôles pour améliorer la scalabilité, et ajoute des règles de détection personnalisées, la corrélation, la détection de vulnérabilités, l'alerting et la gestion du cycle de vie des journaux.

local_rules.xml

```
<!-- Local rules -->

<!-- Modify it at your will. -->
<!-- Copyright (C) 2015, Wazuh Inc. -->

<!-- Example -->
<group name="local,syslog,sshd,">

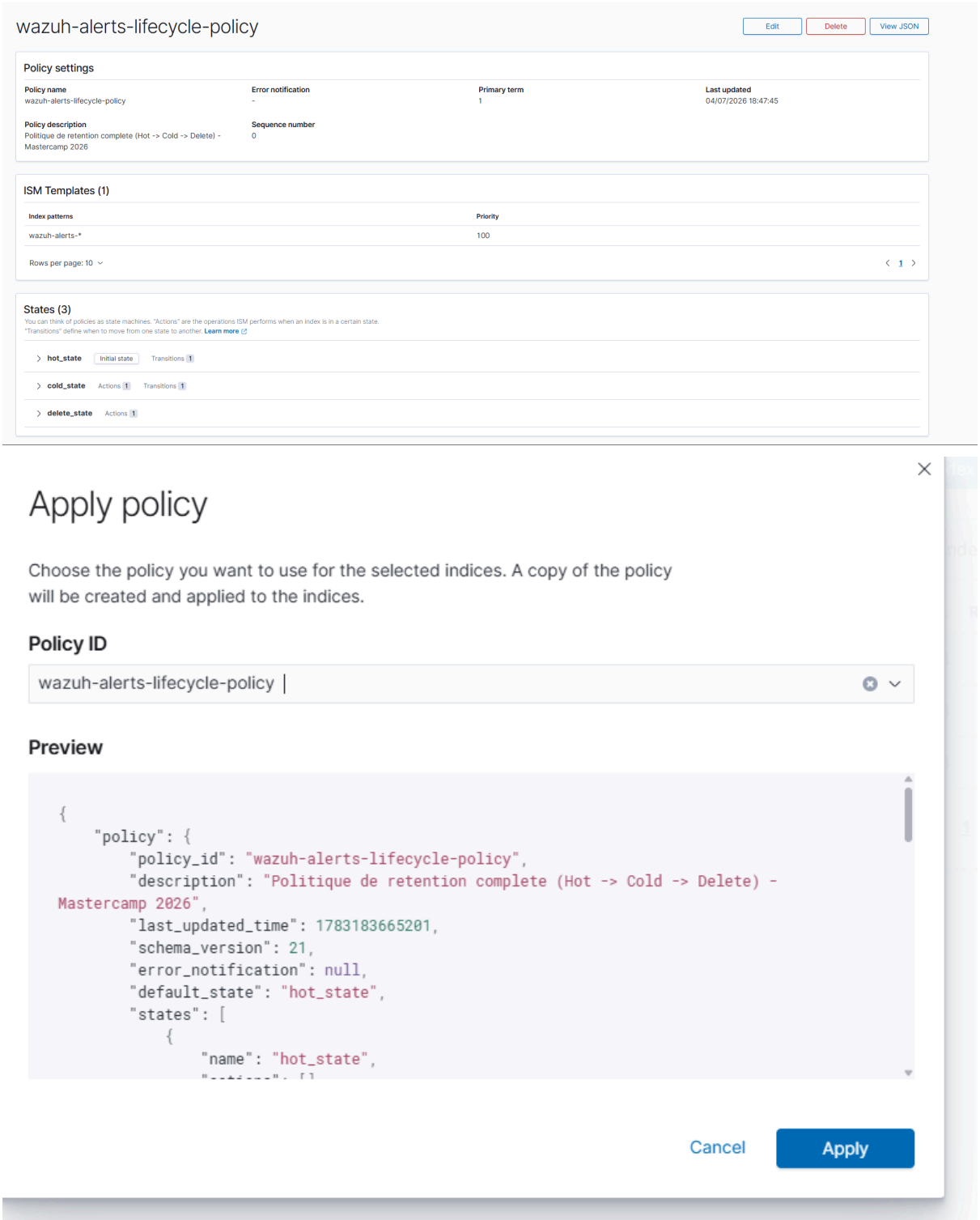
  <rule id="100100" level="10" frequency="5" timeframe="120">
    <if_matched_sid>5710</if_matched_sid>
    <description>Attaque Brute Force SSH detectee (Multiples echecs - Custom)</description>
    <mitre>
      <id>T1110</id>
    </mitre>
    <group>authentication_failed,vulnerability_attack,</group>
  </rule>

</group>
```

Règle de détection brute-force

Jul 2, 2026 @ 20:36:10.664	ubuntu-server-interne	sshd: brute force trying to get access to the system. Authentication failed.	10	5763
Jul 2, 2026 @ 20:35:08.436	ubuntu-server-interne	Attaque Brute Force SSH detectee (Multiples echecs - Custom)	10	100100
Jul 2, 2026 @ 20:34:06.498	ubuntu-server-interne	Attaque Brute Force SSH detectee (Multiples echecs - Custom)	10	100100
Jul 2, 2026 @ 20:34:06.361	ubuntu-server-interne	Attaque Brute Force SSH detectee (Multiples echecs - Custom)	10	100100

Alerte brute-force

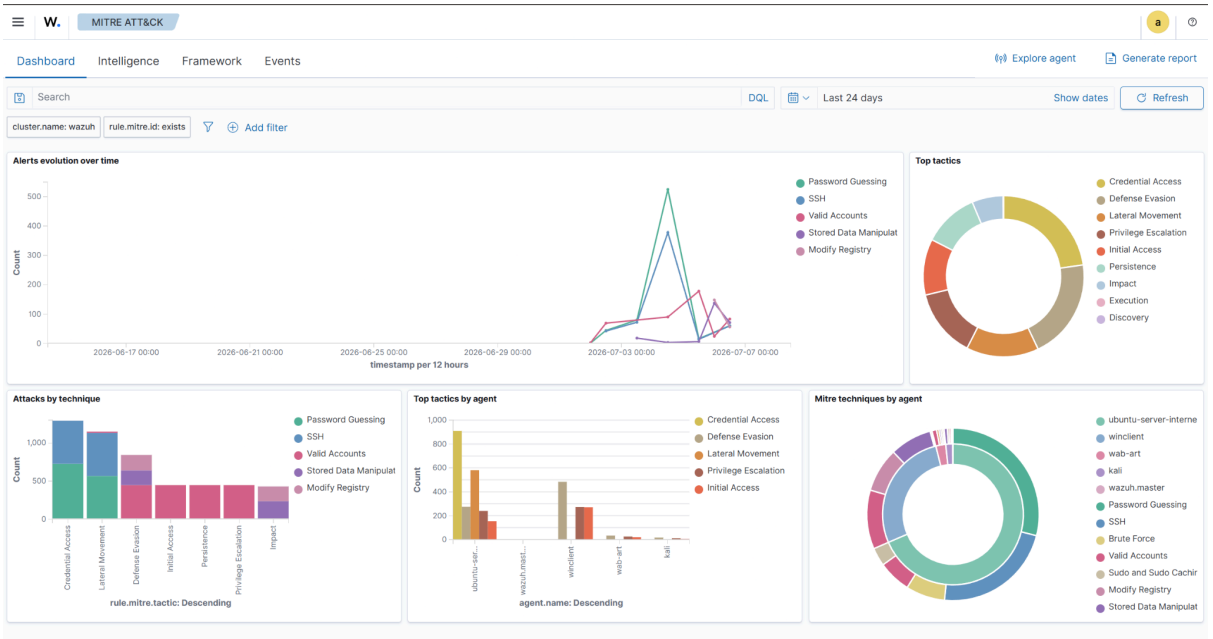


Politique de rétention ISM

Le volet conformité de cette phase (RGPD renforcé + ISO/IEC 27001) est traité au chapitre 7.

6. Phase 3 - Cluster et conteneurisation

La troisième phase industrialise la plateforme : cluster résilient, load balancing, threat intelligence, cartographie MITRE, réponse automatisée et intégrations étendues.



Dashboard MITRE ATT&CK

Le volet conformité de cette phase (RGPD + PCI DSS) est traité au chapitre 7.

7. Conformité réglementaire

La conformité est le fil rouge du projet. Elle est traitée de façon transversale ici, en distinguant le socle RGPD (présent dès la Phase 1) puis son renforcement par ISO/IEC 27001 (Phase 2) et PCI DSS (Phase 3).

7.1. Conformité RGPD

7.1.1. FInalité et base légale

Les journaux collectés par la plateforme SIEM/XDR sont traités dans un but unique et explicite : assurer la détection et l'investigation des incidents de sécurité du système d'information. Aucune autre exploitation (profilage, évaluation des personnes, usage commercial) n'est réalisée. Le traitement repose sur l'intérêt

légitime du responsable de traitement (article 6.1.f du RGPD), à savoir garantir la sécurité, l'intégrité et la continuité du système d'information.

7.1.2. Données traitées et minimisation

Conformément au principe de minimisation (article 5.1.c), la plateforme ne collecte que les données strictement nécessaires à la fonction de détection. Le registre des traitements est le suivant :

Données	Source	FInalité	Base légale	Conservation
Adresse IP	Logs agents / Pare-feu	Détection d'attaques, corrélation, blocage	Intérêt légitime (6.1.f)	90j puis archive 12 mois
Nom d'utilisateur	Logs d'authentifiacation	Détection d'accès frauduleux, traçabilité	Intérêt légitime (6.1.f)	90j puis archive 12 mois
Nom de machine	Agents Wazuh	Rattacher un événement à un actif	Intérêt légitime (6.1.f)	90j puis archive 12 mois
Horodatage	Tous les logs	Reconstituer la chronologie d'un incident	Intérêt légitime (6.1.f)	90j puis archive 12 mois

Ces données ne sont pas collectées par confort mais parce qu'elles sont techniquement indispensables : sans l'adresse IP source, il est impossible de détecter une attaque par force brute, de corréler des événements entre systèmes ou de bloquer un attaquant ; sans le nom d'utilisateur, il est impossible de distinguer une connexion légitime d'une connexion frauduleuse ni d'attribuer une action lors d'une investigation. La collecte est donc proportionnée et limitée aux champs nécessaires, sans capter le contenu des communications.

Document Details

View surrounding documents

View single document

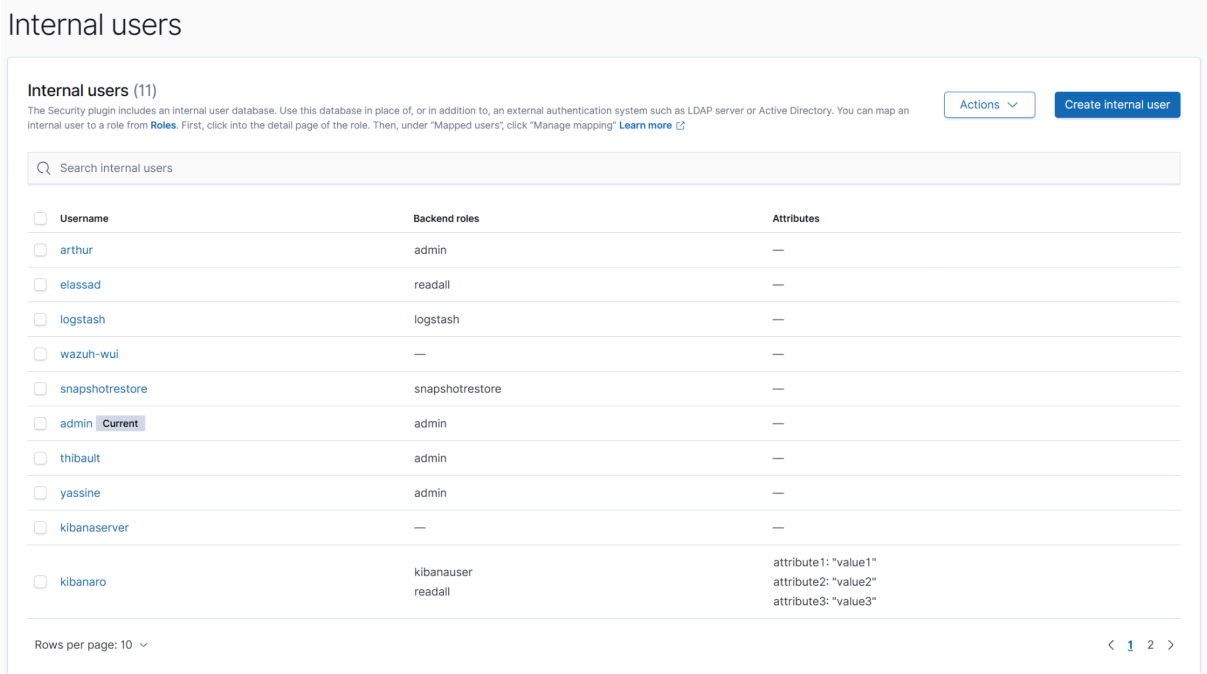
Table | JSON

t _index	wazuh-alerts-4.x-2026.07.06
t agent.id	003
t agent.ip	100.126.57.121
t agent.name	winclient
t cluster.name	wazuh
t cluster.node	worker01
t data.win.eventdata.authenticationPackageName	Negotiate
t data.win.eventdata.elevatedToken	%%1842
t data.win.eventdata.impersonationLevel	%%1833
t data.win.eventdata.keyLength	0
t data.win.eventdata.logonGuid	{00000000-0000-0000-0000-000000000000}
t data.win.eventdata.logonProcessName	Advapi
t data.win.eventdata.logonType	5
t data.win.eventdata.processId	0x314
t data.win.eventdata.processName	C:\\Windows\\System32\\services.exe
t data.win.eventdata.subjectDomainName	WORKGROUP
t data.win.eventdata.subjectLogonId	0x3e7
t data.win.eventdata.subjectUserName	DESKTOP-CB5SCHU$
t data.win.eventdata.subjectUserSid	S-1-5-18

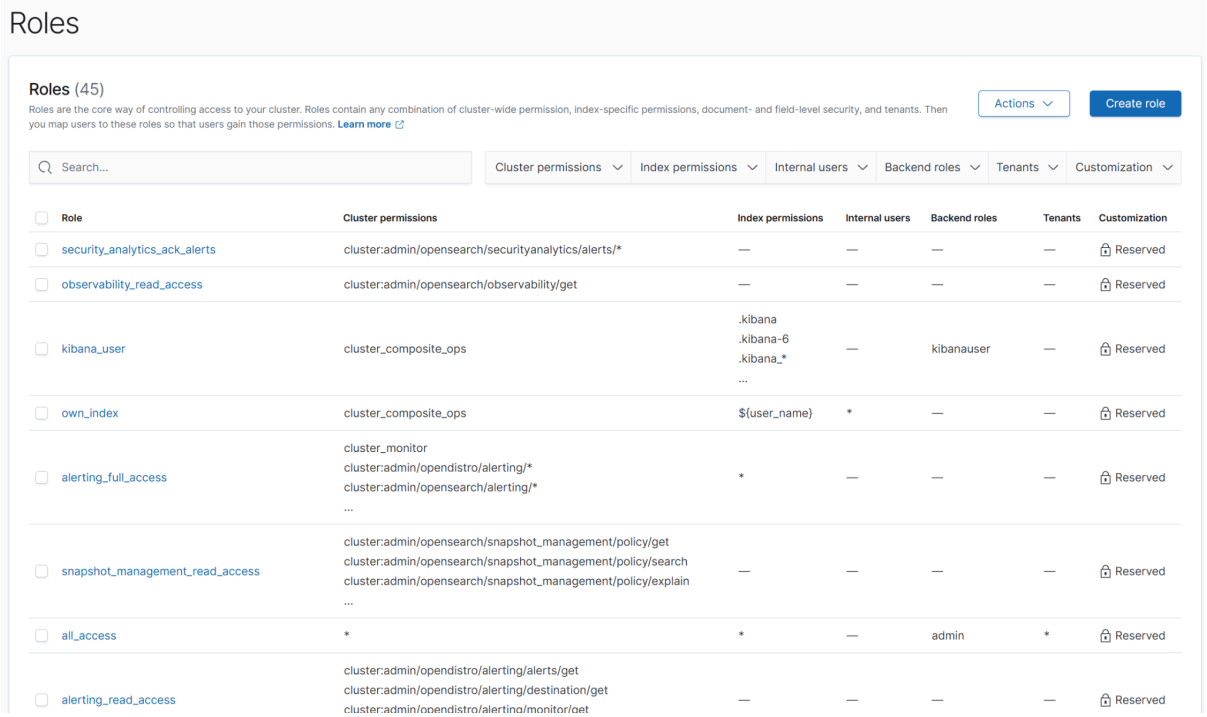
Preuve d'événement déplié montrant une adresse IP source et un nom d'utilisateur

7.1.3. Contrôle d'accès et sécurité (article 32)

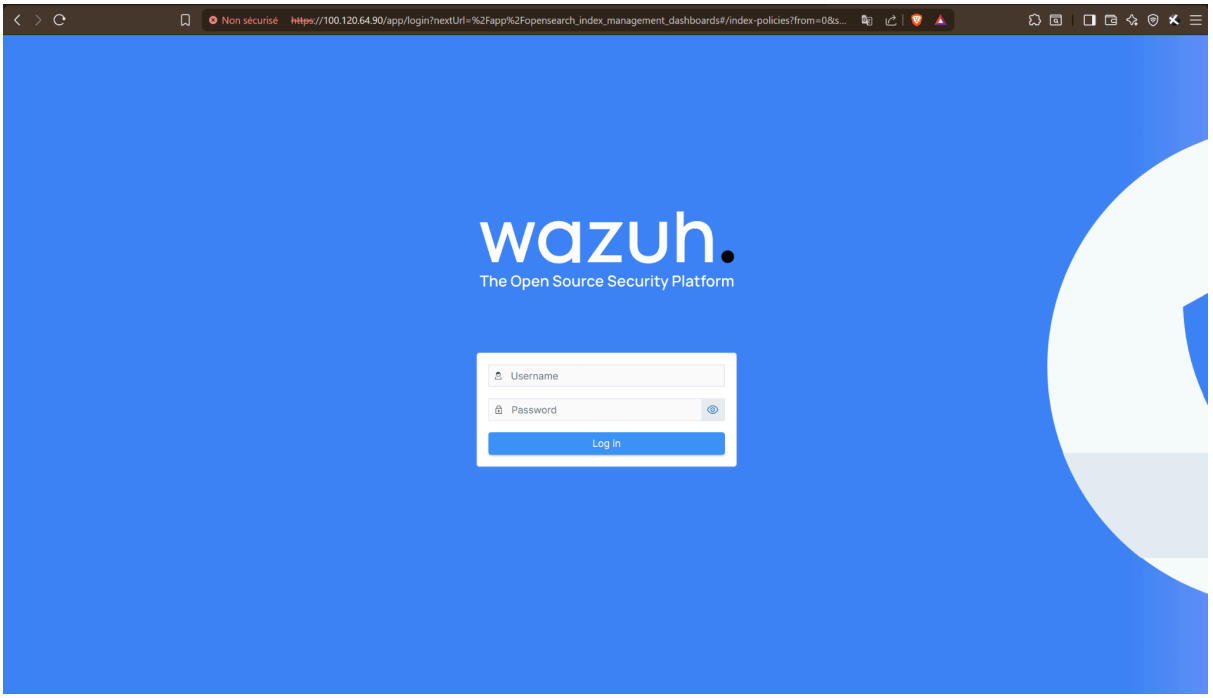
L'accès à la plateforme est protégé par une authentification et une gestion des rôles (RBAC) : chaque membre dispose d'un compte nominatif et de droits limités au strict nécessaire (principe du moindre privilège). Les communications entre les agents et le serveur, ainsi que l'accès au tableau de bord, sont chiffrées via TLS ; l'accès distant s'effectue exclusivement au travers du VPN Tailscale (chiffré), aucun service n'étant exposé sur l'Internet public. Ces mesures répondent à l'exigence de sécurité du traitement (article 32 du RGPD).



Liste des utilisateurs internes



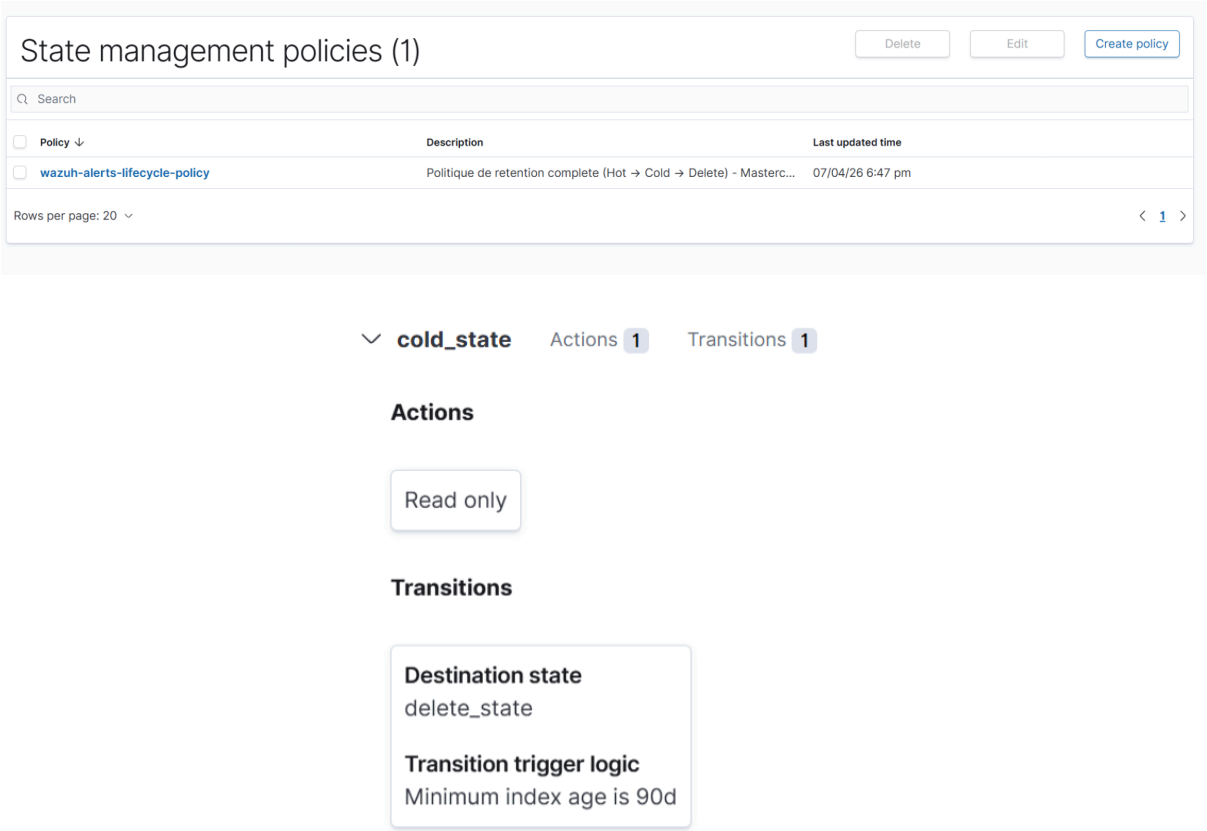
Liste des rôles



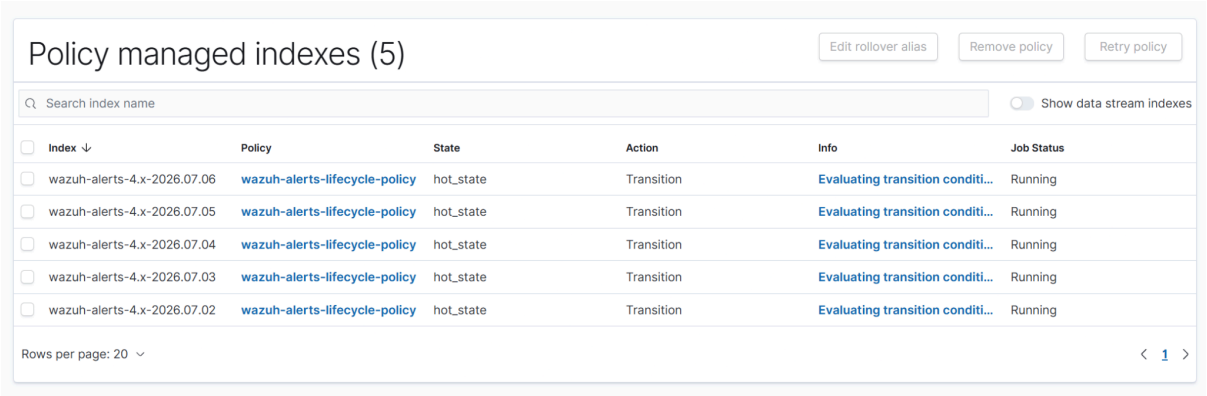
Ecran de connexion Wazuh

7.1.4. Politique de rétention

Les alertes et événements de sécurité sont conservés en accès immédiat pendant 90 jours. Cette durée répond au besoin opérationnel d'investigation et de corrélation; au-delà, la valeur opérationnelle des données décroît fortement, conformément au principe de limitation de la conservation (article 5.1.e). Pour répondre à l'exigence PCI DSS 10.5.1 (voir 7.3), un archivage en stockage froid, jusqu'à 12 mois, complète ce dispositif : les 90 jours en accès immédiat couvrent les « trois mois immédiatement disponibles », et l'archivage couvre les « douze mois » de rétention totale.



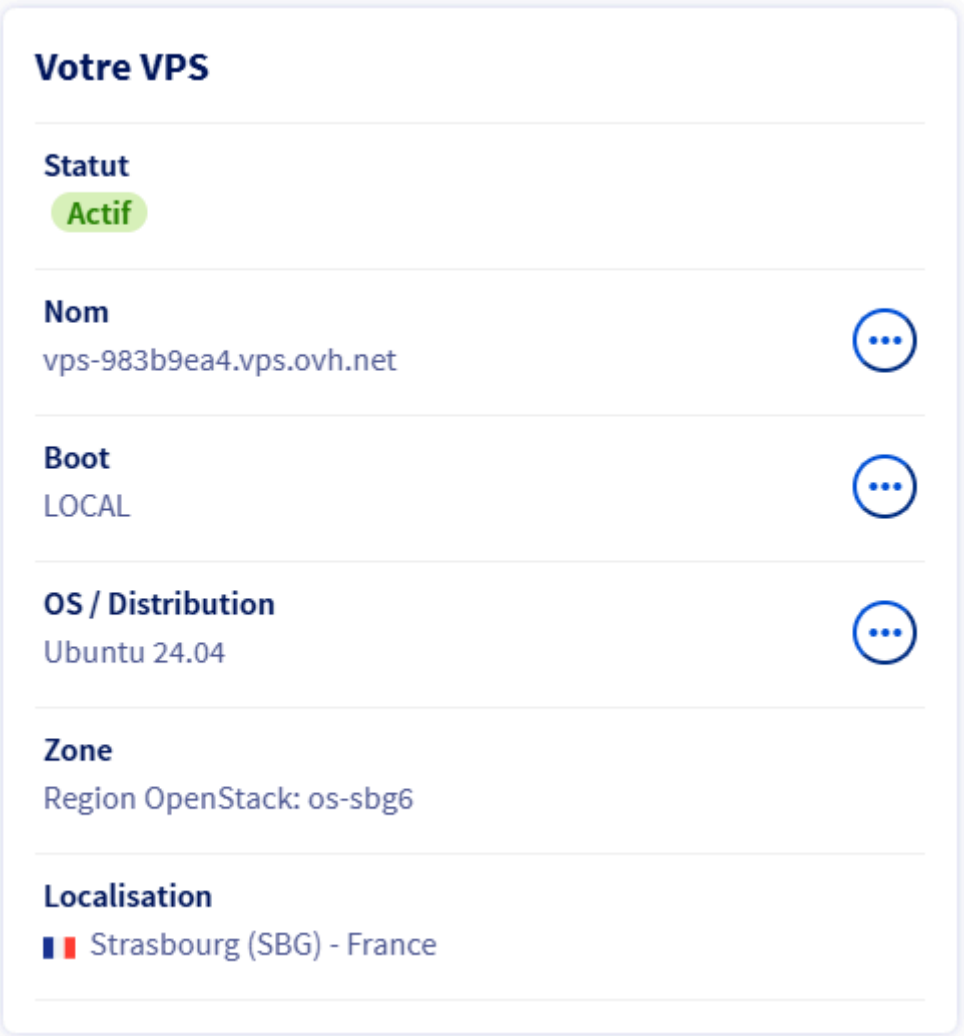
Politique de rétention à 90 jours



*Association aux index wazuh-alerts-**

7.1.5. Localisation des données

L'ensemble des données est hébergé chez OVHcloud, au datacenter de Strasbourg (France), donc au sein de l'Union européenne. Aucun transfert hors UE n'est réalisé, ce qui garantit l'application pleine et entière du RGPD.



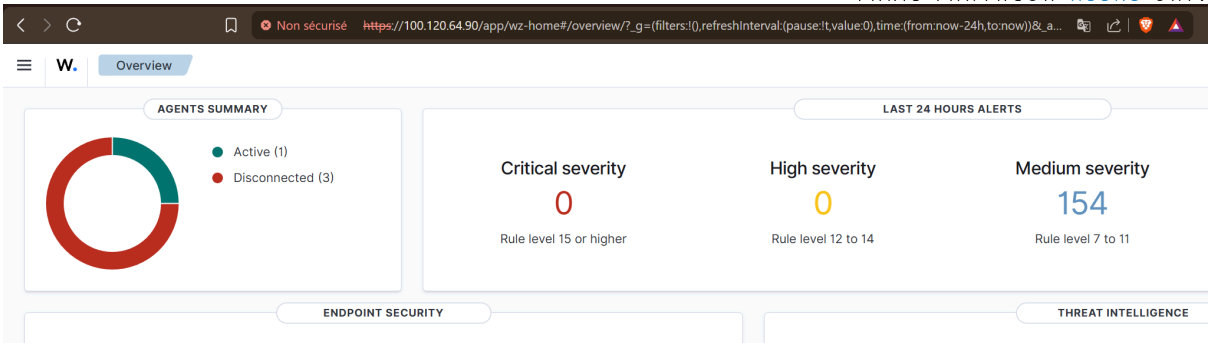
7.1.6. Analyse de risque (synthèse)

Une analyse de risque simplifiée a été conduite sur les données personnelles traitées : les données concernées (IP, comptes, noms de machines) ne sont accessibles qu'aux membres habilités via des comptes nominatifs et un contrôle d'accès par rôles ; elles sont protégées par le chiffrement, le VPN, l'hébergement en UE et une rétention limitée. En cas de fuite, le risque se limite à la divulgation d'informations techniques internes, fortement atténuées par ces mesures ; en cas d'incident, la plateforme le détecte elle-même, les accès peuvent être révoqués et le système restauré depuis un snapshot.

7.2. Conformité ISO/IEC 27001 (Phase 2)

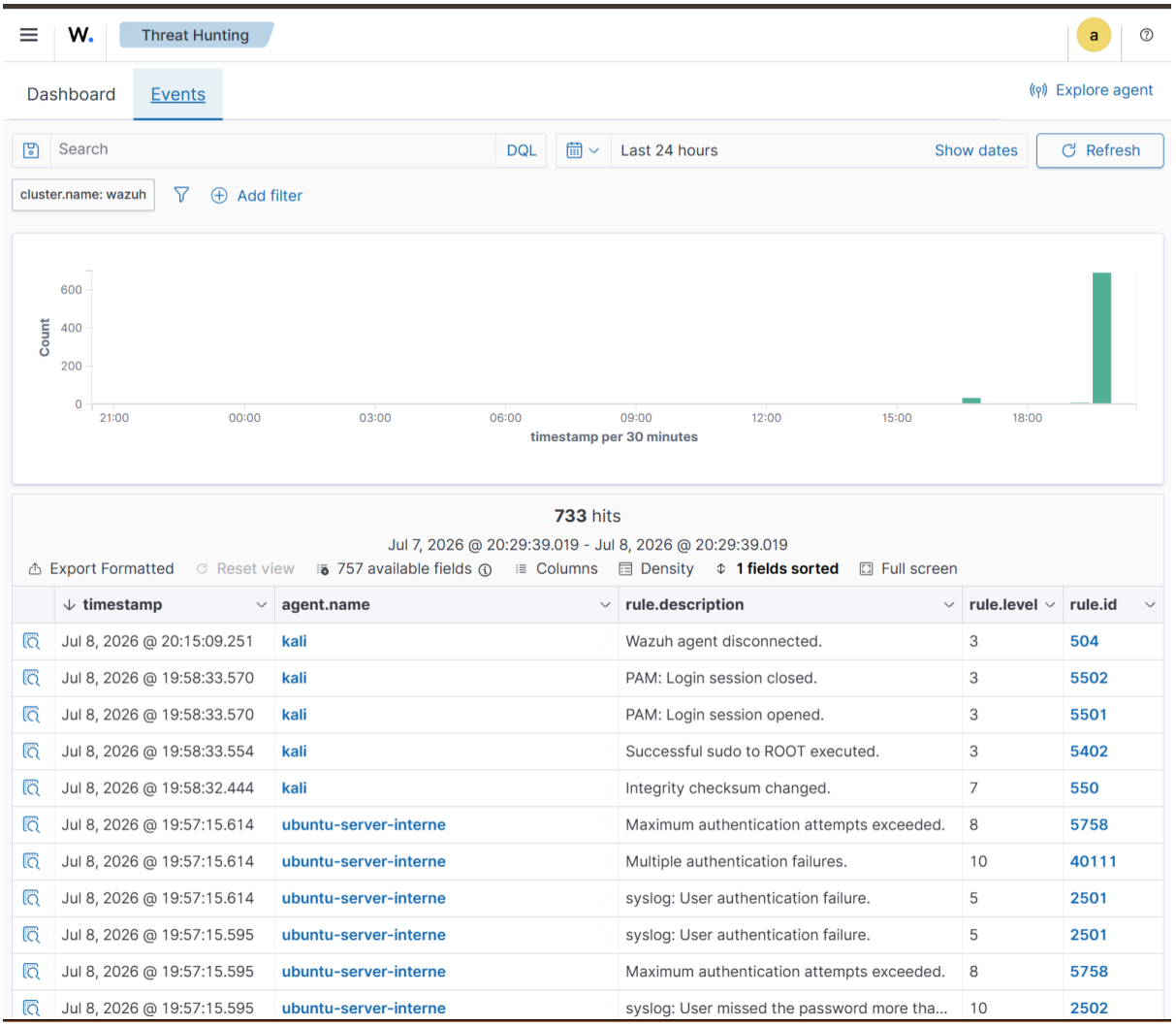
À partir de la Phase 2, les mesures RGPD sont rattachées aux contrôles ISO/IEC 27001 correspondants, en s'appuyant sur le tableau de bord de conformité intégré à Wazuh.

Mesure mise en place	Contrôle ISO/IEC 27001
Contrôle d’accès (RBAC)	A.9 - Contrôle d’accès
Chiffrement TLS / VPN	A.10 - Cryptographie
Journalisation et horodatage (NTP)	A.12.4 - Journalisation et surveillance
Rétention et suppression des journaux	A.18 - Conformité



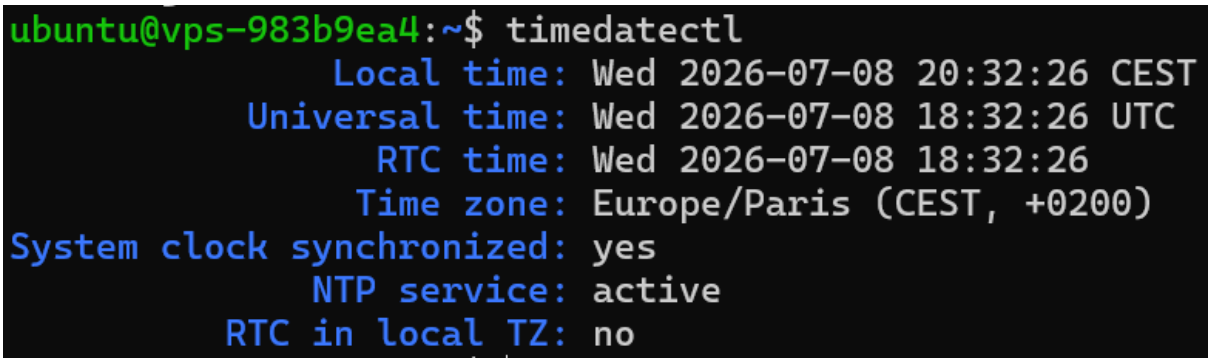
A.10 - Preuve de page chiffrée via TLS

(Nous pouvons noter que la page est montré “Non-sécurisé” car Wazuh génère un certificat auto-signé)

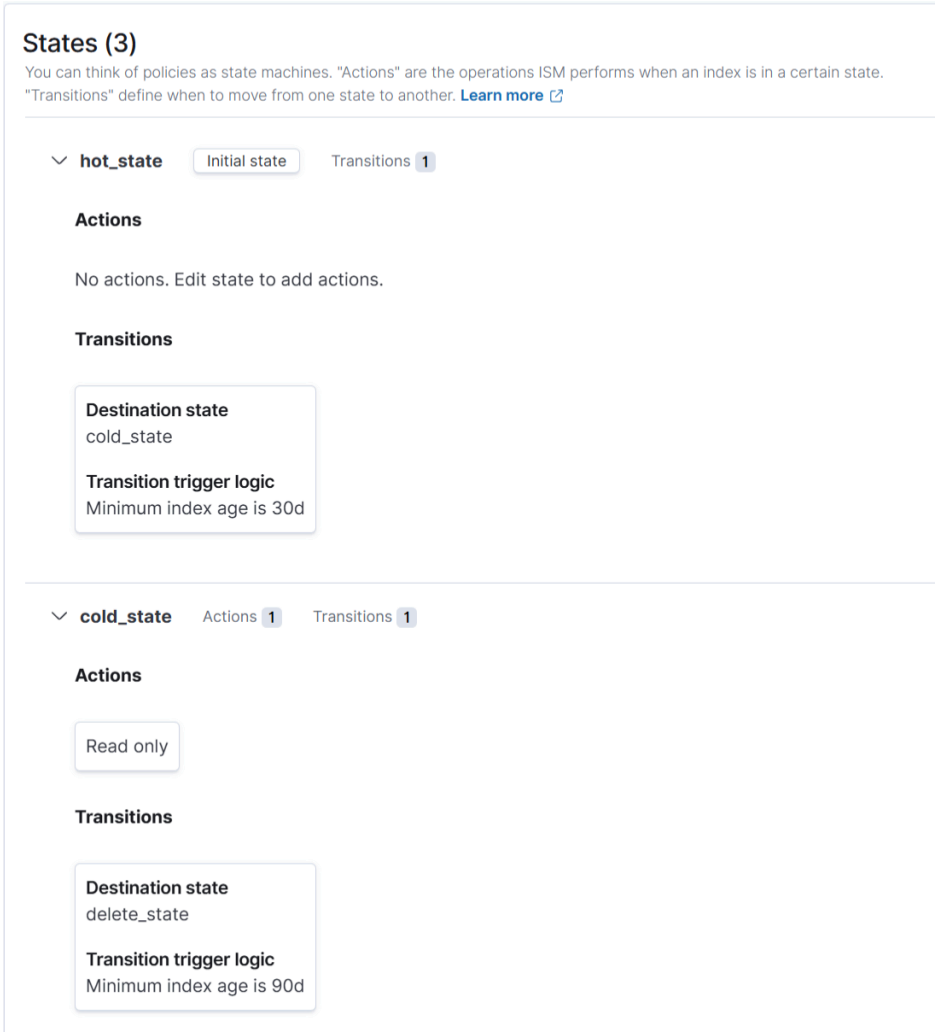


timestamp	agent.name	rule.description	rule.level	rule.id
Jul 8, 2026 @ 20:15:09.251	kali	Wazuh agent disconnected.	3	504
Jul 8, 2026 @ 19:58:33.570	kali	PAM: Login session closed.	3	5502
Jul 8, 2026 @ 19:58:33.570	kali	PAM: Login session opened.	3	5501
Jul 8, 2026 @ 19:58:33.554	kali	Successful sudo to ROOT executed.	3	5402
Jul 8, 2026 @ 19:58:32.444	kali	Integrity checksum changed.	7	550
Jul 8, 2026 @ 19:57:15.614	ubuntu-server-interne	Maximum authentication attempts exceeded.	8	5758
Jul 8, 2026 @ 19:57:15.614	ubuntu-server-interne	Multiple authentication failures.	10	40111
Jul 8, 2026 @ 19:57:15.614	ubuntu-server-interne	syslog: User authentication failure.	5	2501
Jul 8, 2026 @ 19:57:15.595	ubuntu-server-interne	syslog: User authentication failure.	5	2501
Jul 8, 2026 @ 19:57:15.595	ubuntu-server-interne	Maximum authentication attempts exceeded.	8	5758
Jul 8, 2026 @ 19:57:15.595	ubuntu-server-interne	syslog: User missed the password more tha...	10	2502

A.12.4 - Preuve de journalisation des logs



A.12.4 - Preuve d'un horodatage fiable (NTP)



A.18 - Preuve de rétention et suppression des journaux

7.3. Conformité PCI DSS (Phase 3)

La norme PCI DSS (exigence 10.5.1, version 4.0) impose de conserver l'historique des journaux d'audit pendant au moins 12 mois, dont au minimum les 3 mois les plus récents immédiatement disponibles. Le modèle de rétention à deux niveaux mis en place (90 jours en accès immédiat dans l'indexeur, puis archivage en stockage froid jusqu'à 12 mois) satisfait cette exigence tout en respectant le principe RGPD de limitation de la conservation. Le chiffrement des communications entre nœuds et la gestion des secrets des conteneurs complètent le dispositif.

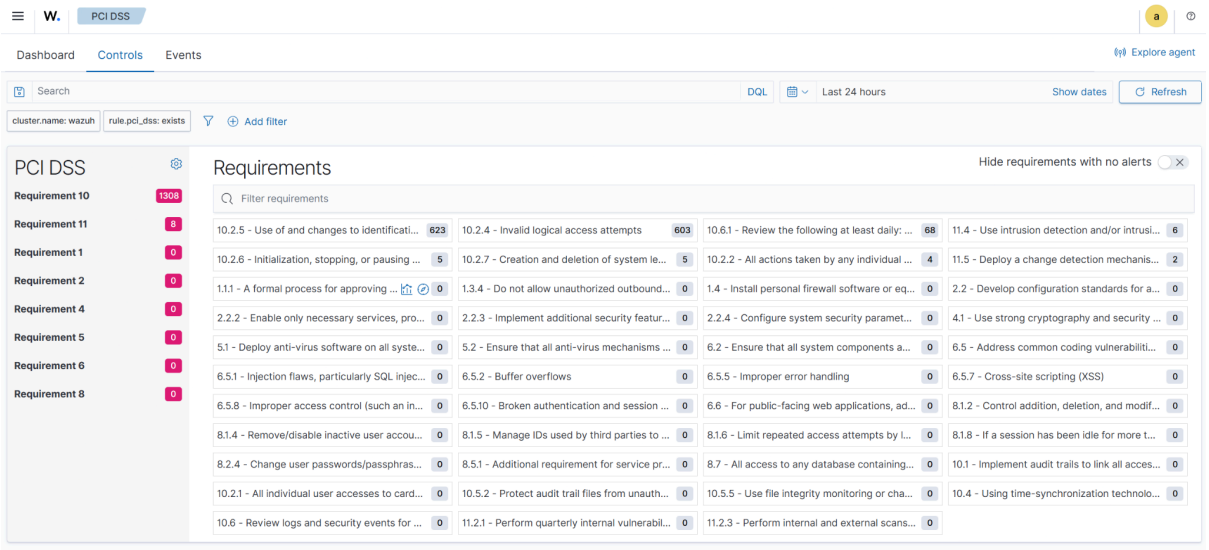


Tableau de bord PCI DSS

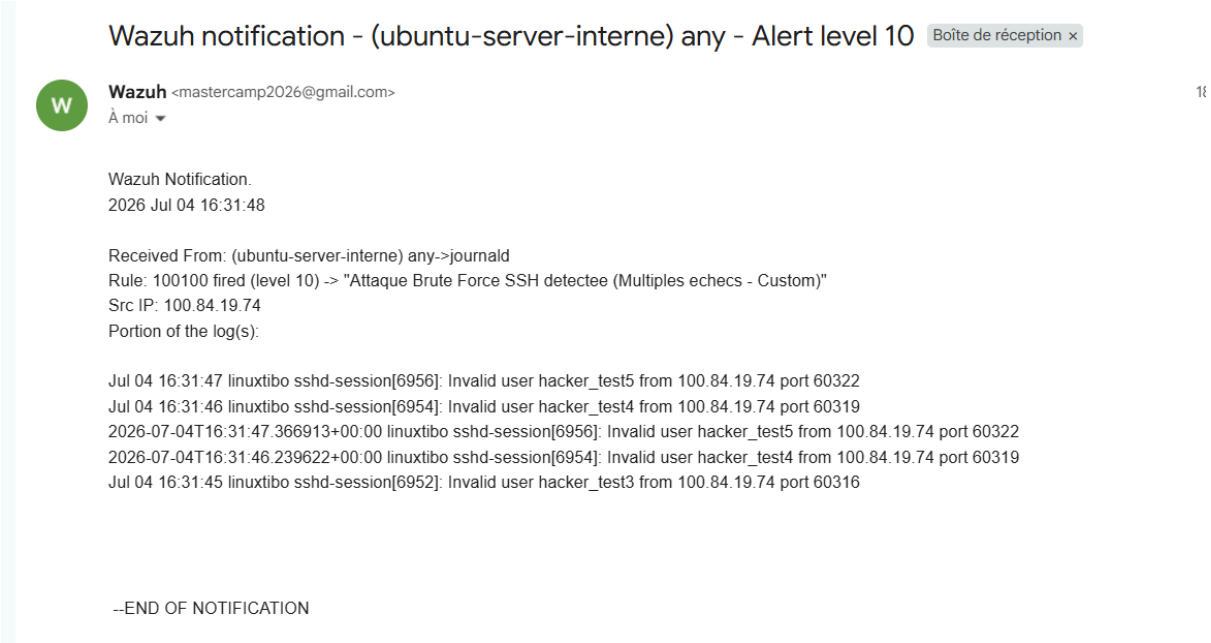
8. Cas d'usage et démonstrations

Cette section présente les scénarios de détection démontrés sur la plateforme.

Brute Force :

```
┌──(kali㉿kali)-[~]
└─$ for i in 1 2 3 4 5 6; do sshpass -p "wrongpass$i" ssh -o StrictHostKeyChecking=no -o ConnectTimeout=3 hacker_tes
t$i@100.82.248.13; sleep 1; done
Connection closed by 100.82.248.13 port 22
Connection closed by 100.82.248.13 port 22
Connection closed by 100.82.248.13 port 22
Connection closed by 100.82.248.13 port 22
Connection closed by 100.82.248.13 port 22
Connection closed by 100.82.248.13 port 22
```

1.Commande exécutée par l'attaquant



Wazuh notification - (ubuntu-server-interne) any - Alert level 10 Boîte de réception ×

Wazuh <mastercamp2026@gmail.com>
À moi

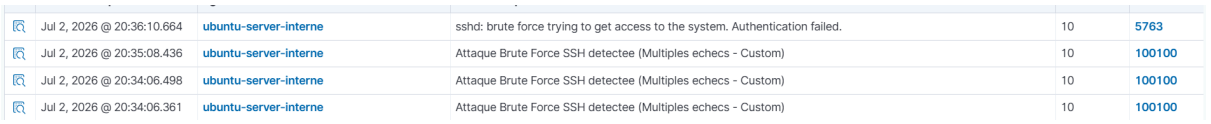
Wazuh Notification.
2026 Jul 04 16:31:48

Received From: (ubuntu-server-interne) any->journald
Rule: 100100 fired (level 10) -> "Attaque Brute Force SSH detectee (Multiples echecs - Custom)"
Src IP: 100.84.19.74
Portion of the log(s):

Jul 04 16:31:47 linuxtibo sshd-session[6956]: Invalid user hacker_test5 from 100.84.19.74 port 60322
Jul 04 16:31:46 linuxtibo sshd-session[6954]: Invalid user hacker_test4 from 100.84.19.74 port 60319
2026-07-04T16:31:47.366913+00:00 linuxtibo sshd-session[6956]: Invalid user hacker_test5 from 100.84.19.74 port 60322
2026-07-04T16:31:46.239622+00:00 linuxtibo sshd-session[6954]: Invalid user hacker_test4 from 100.84.19.74 port 60319
Jul 04 16:31:45 linuxtibo sshd-session[6952]: Invalid user hacker_test3 from 100.84.19.74 port 60316

--END OF NOTIFICATION

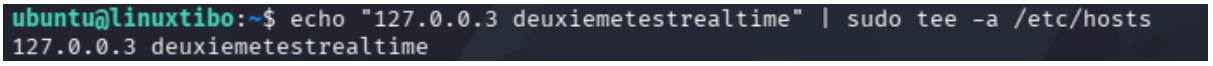
2.1.Alerte reçu par mail



Jul 2, 2026 @ 20:36:10.664	ubuntu-server-interne	sshd: brute force trying to get access to the system. Authentication failed.	10	5763
Jul 2, 2026 @ 20:35:08.436	ubuntu-server-interne	Attaque Brute Force SSH detectee (Multiples echecs - Custom)	10	100100
Jul 2, 2026 @ 20:34:06.498	ubuntu-server-interne	Attaque Brute Force SSH detectee (Multiples echecs - Custom)	10	100100
Jul 2, 2026 @ 20:34:06.361	ubuntu-server-interne	Attaque Brute Force SSH detectee (Multiples echecs - Custom)	10	100100

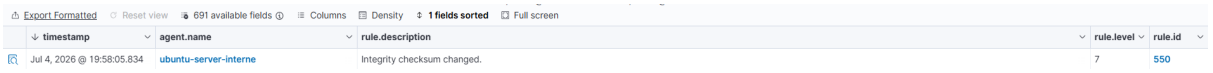
2.2.Alerte reçu sur le tableau de bord Wazuh

File Integrity Monitoring :



```
ubuntu@linuxtibo:~$ echo "127.0.0.3 deuxiemetestrealtime" | sudo tee -a /etc/hosts
127.0.0.3 deuxiemetestrealtime
```

1.Commande lancée pour modifier un fichier critique factice pour déclencher une alerte d'intégrité de niveau élevé



Export Formatted | Reset view | 691 available fields | Columns | Density | 1 fields sorted | Full screen

timestamp	agent.name	rule.description	rule.level	rule.id
Jul 4, 2026 @ 19:58:05.834	ubuntu-server-interne	Integrity checksum changed.	7	550

2.Alerte reçu sur le tableau de bord

Processus Suspect :

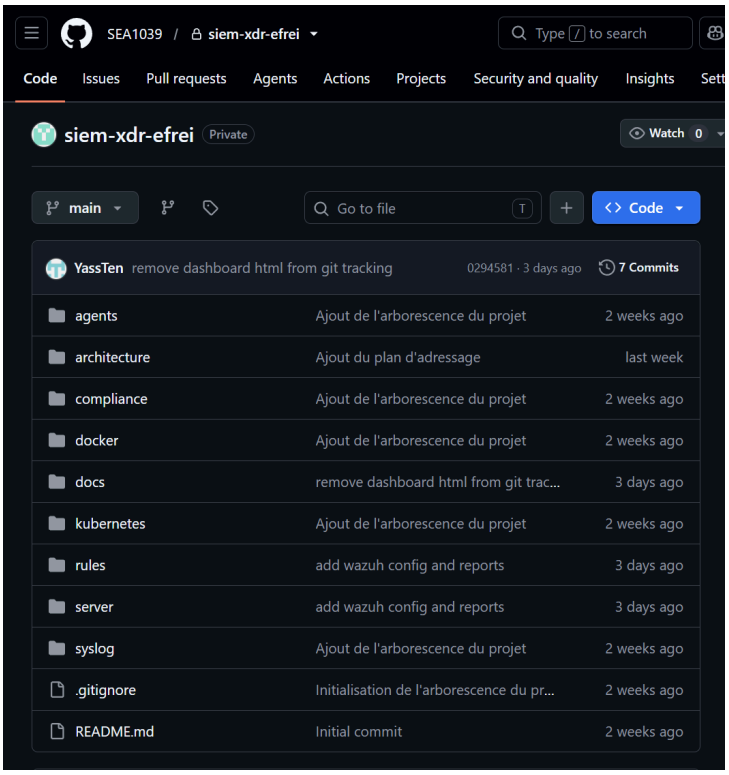
```
ubuntu@linuxtibo:~$ find / -perm -4000 -type f 2>/dev/null | head -n 5
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/openssh/ssh-keysign
/usr/lib/cargo/bin/su
/usr/lib/cargo/bin/sudo
/usr/bin/su
ubuntu@linuxtibo:~$ cat /etc/shadow 2>/dev/null
```

1. Un attaquant tente de fouiller le système à la recherche d'informations sensibles ou qui utilise des outils de hacking

2.Wazuh le détecte

9. Organisation et gestion de projet

Le projet est mené par une équipe de six étudiants travaillant à distance, avec une répartition des rôles : chef de projet et architecte, lead infrastructure, lead endpoints et sources, lead détection et threat intel, lead conformité et documentation, et lead DevOps / conteneurisation. Le travail est organisé en sprints, le code et les configurations étant versionnés dans un dépôt Git commun avec revue croisée des modifications.



Dépôt Git commun pour la documentation

10. Conclusion

Ce projet met en œuvre une démarche progressive de conception d'une plateforme SIEM/XDR, d'une architecture centralisée vers une solution distribuée et conteneurisée de niveau entreprise, sur une base open-source (Wazuh) hébergée en Union européenne. À chaque palier, la plateforme est complétée d'un volet de conformité (RGPD, puis ISO/IEC 27001 et PCI DSS) documenté et étayé par des preuves.